VAULTLINE

2026 深圳国际金融科技大赛 · 人工智能赛道

Vaultline 安全自评报告

权限分级、授权边界、控制证据与已知风险

模型提议，服务端裁决，回执证明结果。

06	08 / 08	100%	0
核心银行场景	安全评测通过	关键动作审计覆盖	重复资金副作用

SECURITY SELF-ASSESSMENT

安全、可审计、可控制的银行 AI 智能体

本地合成账本 / Go 服务端授权 / 六场景真实业务链路

本文件不包含真实账户、真实资金或生产凭据。

版本 v1.0 · 2026-11-01 · Vaultline 项目组

SYNTHETIC DATA ONLY

自评结论

当前实现已完成“自然语言请求 - 服务端动作 - 用户确认或 MFA - 业务回执”的可执行安全链路。

8 / 8	100%	100%	0
安全用例通过	不变量通过	审计覆盖	重复副作用

自评结论：当前实现的核心安全边界成立。模型不能签发授权，用户输入不能改变服务端策略，动作关键字段进入快照后不能静默修改，副作用必须经过一次性执行门，成功状态只来自业务工具回执。

适用范围：普通用户 Web/APP/IM 链路、本地合成账本、服务端配置化 Bearer 网关令牌和本地 MFA 测试验证器。报告覆盖当前代码边界内的实现风险，不把未接入的外部银行核心表述为已完成。

资产 / 对象	实现范围	当前保护
用户身份	配置化网关 Token；固定测试用户映射	SHA-256 摘要、常量时间比较、同源代理注入；请求体 user_id 不被信任
资金与账本	本地合成余额	SQLite 事务、整数最小货币单位、幂等执行
动作与授权	六场景 Action	快照哈希、风险策略、确认、MFA、有效期
输入边界	自然语言与结构化 API	隐藏字符清理、高置信注入拒绝、Schema 与工具白名单
可信执行凭证	Action / MFA / Receipt	服务端生成 Source、Identity、Outcome 三类证据
审计	Trace 与事件链	资源级归属校验、敏感字段脱敏
模型与工具	DeepSeek Adapter + 白名单工具	Schema、工具白名单、无任意代码执行

1. 权限分级机制

绿色自动、黄色明确确认、红色动作绑定 MFA。级别由服务端策略计算，不由模型或前端指定。

级别	典型动作	执行策略	失败 / 退出
绿色	余额、流水、账单、产品、卡片、订阅查询与提醒	意图明确后执行只读工具，直接返回服务端事实	参数错误、资源越权、无数据空态
黄色	日累计不超过 1000 元转账、AA 收款请求、虚拟卡申请、卡片冻结、订阅取消、低额外部订单	展示不可变动作快照，等待明确确认	取消、过期、余额不足、日累计复核失败
红色	超过 1000 元转账、理财申购/赎回、额度调整、解冻、挂失/解挂、预算锁和超阈值订单	MFA 必须绑定 action_id；通过后仍需执行门	MFA 失败、锁定、过期、快照变化、工具失败

风险升级在动作创建和执行前都重新计算。示例：当天已成功转出 800 元，再发起 300 元转账时，服务端预计日累计 1100 元，动作从黄色升级为红色；即使动作创建时是黄色，确认时累计金额变化也会使执行失败并要求重新发起。

> 责任边界：前端只展示动作详情、接收确认和 MFA 输入；模型只提供候选计划；最终风险等级、用户归属、授权状态、执行结果和成功状态均由 Go 服务端决定。

2. 动作授权链与状态机

动作快照、确认/MFA、一次性执行门和幂等共同构成副作用边界。

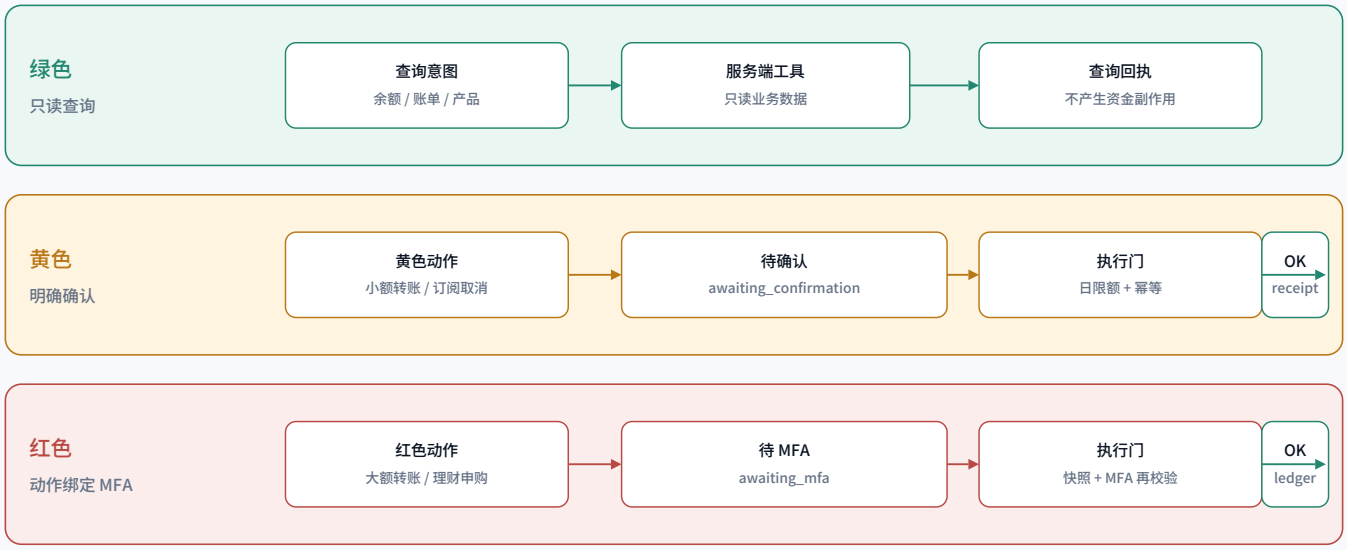


图 1 绿色、黄色、红色动作的授权状态。

控制项	实现	验证
动作快照	关键字段写入 SnapshotJSON，保存 SHA-256 snapshot_hash	授权和执行前复核哈希
黄色确认	仅黄色且 awaiting_confirmation 可确认，审计 confirmation_succeeded	并发确认只执行一次
红色 MFA	MFA 绑定 action_id，默认 5 分钟；连续错误 3 次锁定 Action	错误码、过期和重放测试
预约动作	授权后 scheduled；到期显式 trigger；红色重新 MFA	到期与二次授权测试
取消 / 过期	条件状态更新，释放预算预留，写审计	取消与确认竞争单赢家
执行门	复核状态、快照、日累计、余额、预算和幂等后启动副作用	工具失败或未知不伪造成功

成功状态只能由账本、持仓、卡片或订阅工具回执写入。动作创建、授权和执行结果共用 trace_id；审计事件不能替代业务回执。取消与确认、确认与执行都通过原子竞争边界裁决。

3. 防幻觉、防提示注入与工具边界

用户输入是不可信数据。模型可以理解它，但不能让系统改变权限或执行状态。

攻击 / 风险	控制措施	可执行证据
提示注入	策略不读取 Prompt；固定意图；Schema；工具白名单	prompt_injection_not_executed
零宽字符 / Unicode 标签	输入清理后再做意图解析；高置信指令返回 rejected	prompt_injection_not_executed + input_hidden_characters_removed
模型伪造 user_id / risk / status	授权字段被忽略，服务端从会话和策略重建	unknown_field_rejected / handler tests
模型编造余额、交易或收益	只返回工具数据；最终文案使用结构化字段	查询结果与工具回执一致性测试
模型声称执行成功	成功只能由工具回执和数据库状态产生	action_succeeded 仅在 receipt 后写入
工具名注入	计划节点必须映射到服务端白名单，不存在动态工具	validate plan + handler tests
任意代码执行	当前没有代码执行入口，不暴露 Shell/SQL	代码路径审计

模型输出必须经过固定 Schema。金额、收款人、产品、日期和授权状态由服务端重新校验；解析失败、字段缺失或冲突时追问，无法确认时降级为查询或不执行。模型输出不是授权证据，前端展示也不是业务回执。

> MCP 边界：首期不启动独立 MCP Server。未来跨进程工具必须使用服务间认证、参数 Schema、超时、结构化回执和 reconciliation_required 对账；资金工具不自动重试。

4. 幂等、并发与审计

重复确认不能重复扣款，取消与确认不能同时成功，每个关键动作必须留下可定位的证据链。

控制项	当前实现	已知限制
Idempotency-Key	按用户、方法、路径和请求指纹预留；相同键复用原结果，指纹变化拒绝	最终响应落库失败时保留 pending 并标记 degraded
一次性执行门	状态条件和 SQLite 事务共同裁决；副作用启动前再次复核	本地单实例语义，不代表多实例数据库
并发确认	只有一个请求通过状态更新并产生副作用	已通过 handler 并发测试
取消 / 确认竞争	取消仅作用于 pending 状态；执行后不可取消	已执行资金动作进入人工复核
审计覆盖	trace_id 关联动作创建、授权、执行门和最终回执	外部审计消费者与告警未接入
敏感字段	日志、Trace 和页面不输出密码、验证码、Token 或完整账户号	数据留存与删除策略仍是演示级

当前评测验证了相同幂等键重放后的账户余额变化为 0，重复资金副作用为 0，关键动作审计覆盖为 2/2。审计记录用于定位证据，不替代动作快照、授权结果或业务工具回执。

5. 异常熔断、运行控制与失败状态

系统必须能说明账户是否发生变化，不能把未知回执伪装成成功或静默回滚。

场景	服务端行为	账户 / 动作结果
MFA 连续错误	Action 3 次错误后锁定；用户级失败触发写操作冷却	动作 failed；账户不变
可疑输入 / 注入	用户级安全锁定 15 分钟，查询保持可用	写操作拒绝；审计记录
动作过期	pending 动作进入 expired，释放预算预留	账户不变；需重新发起
用户中断 Run	冻结后续计划生成；记录 run_interrupted	未生成动作无副作用
人工接管	停止模型推进；记录 run_human_handoff	模型不能继续创建副作用
撤销 pending Action	条件取消并释放预算	账户不变；取消可证
已执行资金动作	进入人工复核 / 补偿，不静默冲正	保留业务回执和审计
工具超时 / 未知	进入 reconciliation_required；禁止盲目重试	最终状态待对账

失败安全目标不是“所有动作都成功”，而是所有结果都可解释：成功有业务回执，失败有稳定错误码，取消/过期/锁定有状态和审计，未知回执进入对账而不是盲目重试。

6. 验证证据与安全指标

集成、浏览器 E2E 和工程不变量分别统计；比率指标给出 Wilson 95% 置信区间。

156	9 / 9	0%	100%
集成用例	浏览器 E2E	攻击成功率	策略合规率

评测层	用例数	结果
Intent classification	64	Acc 100.0% · Macro-F1 1.000 · kappa 1.000
Slot extraction	10	Exact 100.0% · amount MAE 0.00 minor
Risk policy	20	Accuracy 100.0% · red F1 1.000
Security robustness	48	ASR 0.0% (CI 13.8%) · FPR 0.0%
Replay / concurrency	12 + 16	duplicates 0 · 1 success / 15 conflicts
Browser E2E	9	9/9 passed · console/5xx 0/0

安全验证矩阵	用例	结果
提示注入无法自动执行资金动作	12	余额变化 0
未知授权字段与状态篡改被拒绝	12	HTTP 400 / 12
良性查询与业务请求不被误拒	24	FPR 0%
相同幂等键重放不产生重复副作用	12	duplicate 0
16 路并发确认受一次性执行门约束	16 req	1 成功 / 15 冲突
浏览器成功画面必须存在业务回执	9	9 / 9
高置信注入被拒绝且不创建 Action	12	12 / 12
生产依赖与 Go 漏洞扫描	-	audit 0 / vulncheck 0

HTTP 延迟样本 200 次：p50 0.386 ms，p95 0.580 ms，p99 2.481 ms；均值 95% CI 420.0-501.1 us。Go Benchmark 为 0.455921 ms/op，2,587 iterations，本机 Apple M5 结果仅用于版本回归，不代表生产网络或容量承诺。

身份验证回归覆盖：配置化 Token 接受、默认 Token 拒绝、短 Token 配置拒绝，以及同源代理服务端注入。令牌只保存 SHA-256 摘要并进行常量时间比较；MFA 验证码同样配置化并使用常量时间比较。API 与 Web 均已启用统一安全响应头，生产依赖 audit 与 Go govulncheck 当前均为 0 个已知漏洞。

完整可复现证据：evaluation/results/cases.csv、academic.json、e2e.json、academic-report.html。

6.1 政策与标准映射

把外部要求翻译成服务端控制与可执行证据；这是设计对齐，不宣称获得监管认证。

文件 / 标准	核心要求	Vaultline 控制	可验证证据
金融监管总局《关于银行业保险业人工智能安全开发应用的指导意见》	全生命周期治理、高风险应用准入、关键环节人工监督、透明度与可解释性、数据和供应链安全	Action 状态机、风险分级、MFA、人工接管、Trace、Source/Identity/Receipt 凭证	动作快照、审计时间线、失败安全测试、人工接管记录
CAC / TC260《人工智能安全治理框架》2.0	风险分类分级、研发到退役的全生命周期治理、智能体风险	模型候选计划与确定性策略分离；工具白名单；执行前复核；会话与资源归属校验	模型计划拒绝、越权字段拒绝、工具回执与并发门测试
OWASP GenAI LLM Top 10 2026	Prompt Injection、Excessive Agency、Misinformation、Improper Output Handling	不可信输入边界、最小工具权限、receipt-only success、输出不直接触发资金工具	24 攻击 / 24 良性用例、0% ASR、0% FPR；注入测试返回 rejected
NIST AI 600-1 / AI 100-2e2025	Confabulation、Human-AI configuration、对抗性机器学习风险	结构化事实与证据索引、模型不可声明成功、独立安全回归和失败状态	academic.json、cases.csv、浏览器 E2E、依赖和漏洞扫描

边界说明：本报告将政策要求映射到已实现控制，但不把竞赛 MVP 表述为生产合规认证。真实身份核验、远程工具、银行核心和高可用接入仍需在生产评审中补充供应商协议、数据留存、第三方审计和应急预案。

7. 已知风险清单

当前范围内无高风险未缓解项；剩余项均对应明确的生产化集成边界。

编号	风险	级别	上线前控制
R-01	共享网关 Token 尚未升级为每用户 OIDC 会话	中	令牌摘要、常量时间比较、同源代理、资源归属校验
R-02	SQLite 仅验证单实例并发语义	中	WAL、事务、条件更新、一次性执行门和 16 路并发测试
R-03	上下文留存与删除策略较简化	中	30 分钟内最近 6 条、敏感输入脱敏、会话隔离
R-04	外部审计消费者与 SIEM 未接入	低	统一 Trace、事务内审计和资源级访问校验
R-05	幂等最终响应失败进入 degraded	低	保留 pending 记录并返回原业务结果，不伪装失败

风险统计：高风险未缓解项 0；中风险 3 项；低风险 2 项。远程 MCP、平台 Webhook、真实商户、调度器和高可用属于后续外部集成能力，当前未启用的能力不作为已暴露攻击面。

8. 发布前检查清单与结论

当前版本可以提交评审；生产发布再按下列门槛逐项增强。

发布门槛	检查项	当前状态
身份与授权	OIDC、设备绑定、MFA、会话轮换、注销	网关 Token 已实现；待接入每用户身份
工具安全	mTLS / Token、Schema、超时、对账、无自动重试	白名单工具已实现；远程对账待接入
数据安全	分类、加密、留存、删除、脱敏和访问审计	脱敏与隔离已实现；留存策略待增强
并发与可靠性	并发压测、故障注入、备份恢复、容量指标	单实例并发已验证；多实例待验证
审计与运营	外部审计、SIEM、告警、值班和取证	Trace 与事务内审计已实现；SIEM 待接入
依赖安全	生产依赖漏洞扫描、Go 漏洞扫描、自动升级	audit 0、govulncheck 0；CI/Dependabot 已启用
合规与第三方	第三方安全测试、监管规则、隐私影响评估	提交前需完成正式评审

最终结论：Vaultline 已建立模型与服务端之间的可执行安全边界，并通过 8/8 安全检查、100% 审计覆盖、0 重复资金副作用和 0 流动性黄金用例误差。当前范围内无高风险未缓解项，剩余风险均有对应控制和生产化路径。

本报告与《Vaultline 技术文档》和《Vaultline 答辩材料》使用同一版本数据：2026-11-01。如果代码、权限策略、外部工具或数据范围变化，应重新运行评测并更新三份材料。